EWB Courses: AI Powered Cybersecurity

Assessment 01: Security Foundations

Name	Aaryan Nandkishor Raorane
Batch / group	AI Powered Internship
Assessment	Assessment 01, issued 18 October 2026
Type	Individual work, 100 marks

Index

Section	Contents	Page
Task A	Secure a student account (A1 to A3)	2
Task B	Analyse a suspicious message (B1 to B4)	3
Task C	Triage a sign in alert (C1 to C4)	4
Task D	Review an AI security answer (D1 to D4)	5
Declaration	AI use declaration and evidence notes	6
References	Sources used	6

Task A: Secure a student account

A1 and A2. Risks, impact and controls

Risk	Asset	CIA impact	Control	Limitation
1. Same short password on email and portal	Email and portal accounts	Confidentiality: one guess or leak opens both. Integrity: an intruder can edit work or send mail as Mira.	A long, unique passphrase per account in a password manager. A leak then opens one door, not two.	The master password becomes a single point of failure, and phishing can still steal it.
2. Approving unexpected sign in prompts	Live sessions	Confidentiality and integrity: one approval hands over the account.	Deny any prompt she did not start, and turn on number matching. A blind tap then no longer works.	Still depends on her attention, and repeated prompts wear people down.
3. Postponed updates	Laptop system and files	All three: unpatched flaws let malware read, change or lock files.	Automatic updates. They patch known weaknesses, so a threat has less to use.	Unknown flaws stay open, and restarts interrupt work.
4. One copy of the project	Project files	Availability: theft or failure ends the work. Integrity: damaged files cannot be restored.	A cloud copy plus an external drive copy. A second copy survives losing the first.	Sync can copy a deletion, so test a restore now and then.
5. Friend uses her signed in account	Her sessions, files and linked accounts	Confidentiality and integrity: the friend can read, change or send as Mira.	A separate normal user account for the friend, and a screen lock. Separate accounts keep private files apart by default.	Relies on habit, and an unencrypted disk can still be read if the laptop is lost.

Priorities

I would fix three things first. Password reuse comes first, because one stolen password now opens email and the portal, and the fix is quick. Prompt handling is second. Multifactor sign in is what catches a bad password, so approving prompts blindly switches it off. Shared sessions are third. The friend has access every time the laptop is used, and a guest account costs nothing. Backups and updates follow, since their harm depends on events that may not happen soon.

A3. Authentication versus authorisation

Authentication is proving who you are. When Mira types her password and approves the prompt, the portal is checking that she really is Mira. Authorisation is what the portal then lets her do. She can open her own courses and submit her work, but she cannot change another student's marks. The friend shows why the two are separate: signed in as Mira, he passes authentication and receives all of her permissions.

Task B: Analyse a suspicious message

B1. Warning signs

Quoted phrase	Why it needs scrutiny
"FINAL WARNING" and "expires in 20 minutes"	Manufactured urgency. Scammers rush people so they skip checking.
Display name "Scholarship Desk"	The sender, the link and the reply address sit on three different domains, and none is campus.example. A display name is free text anyone can type.
"enter your college password and OTP"	A password plus a one time code is what a login thief needs. The Day 1 notes say never to share OTPs.
"Do not contact the college office"	It tells the reader to skip the one check that would settle things. The reason given is unverified.
"photo of your identity card"	An ID photo enables identity fraud, and a payment does not need one sent by reply.

B2. Safe verification

I would not click or reply. I would type the college portal address myself, or use the official app, and look for a scholarship notice there. The office phone number should come from the college website or notice board, not from the message. If I am still unsure, the IT helpdesk can look at it.

HTTPS only means the connection to that site is encrypted. Anyone can get a certificate for a lookalike domain, and DNS points a name at whoever registered it, so a padlock says nothing about honesty. The display name is just text the sender typed.

B3. Response plan if a password and OTP were entered

1. Change the college password now, from a trusted device, by typing the official address yourself. Change it anywhere it was reused, and sign out of all sessions.

2. Check MFA devices, recovery email and phone for anything unfamiliar, and look for mailbox forwarding rules.

3. Report to the college IT helpdesk and the scholarship office through official contacts. Keep the message, and say that a password and OTP were entered. Never send the password or OTP to anyone while reporting. If misuse follows, use the national cybercrime portal.

4. Over the next days, review recent sign in activity, run updates and a malware scan, and watch for follow up messages.

B4. What cannot be established

This message alone cannot show who really sent it, or whether the college is involved at all. The full email headers with SPF, DKIM and DMARC results would help, as would confirmation from the scholarship office and word from IT on whether other students got the same message.

Task C: Triage a sign in alert

C1. Timeline

Point	Observed (logs and statement)	Interpretation
1. 09:00 to 09:01	Password success and MFA approved from 192.0.2.10, the usual classroom address. The student says there was no sign in after 09:05.	A normal sign in. This is the baseline.
2. 10:14 to 10:15	Two failed passwords from a new address, 198.51.100.23.	Could be guessing or a leaked password. Could also be typos. Failures alone prove nothing.
3. 10:16 to 10:17	The password succeeded on the third try. Then an MFA prompt was denied.	Whoever typed it knew the password by try three. The logs do not say who denied the prompt.
4. 10:18 to 10:20	MFA approved, then a session created from 198.51.100.23. The student says they approved a prompt near 10:18 to stop the repeated requests.	The approval matches the statement. The student says they did not start a sign in, so they probably approved someone else's attempt, and that source now holds a session.

C2. Likely explanation, alternative and checks

Likely: someone got hold of the password and sent repeated MFA prompts until the student approved one, which is often called MFA fatigue. The new address, the repeated prompts and the student's statement all fit.

Alternative: the student signed in from another network, such as a phone hotspot, and misremembers. The Day 4 notes say an IP address changes whenever a device changes network, and many students can share one outbound address, so an IP points to a network, not a person.

Two checks: (1) Compare the session's device, browser and location with the student's known devices, and see whether 198.51.100.23 belongs to a known VPN or mobile network. (2) Review what the session did after 10:20, such as new MFA methods, forwarding rules or bulk downloads, and ask what the prompt looked like on the student's phone.

C3. Response actions for the IT team

1. **Protect the account.** Revoke active sessions and tokens, reset the password through the official process, and review MFA methods and recovery details.

2. **Preserve evidence.** Export the authentication and session logs, with times, source address and session details, and keep them unedited. Start this at once, alongside step 1.

3. **Investigate and harden.** Check other accounts touched from the same address, review activity since 10:20, switch on number matching and prompt limits, and coach the student on denying unexpected prompts.

C4. Incident summary

On 18 October 2026, student07 signed in normally at 09:00 from the usual classroom address. Between 10:14 and 10:20 the address 198.51.100.23 showed two failed passwords, a correct one, a denied prompt, an approved prompt and a new session. The student says they did not sign in and approved a prompt to stop repeated requests. Unauthorised access is likely but unconfirmed, because an IP does not identify a person. Priority is high. IT should revoke sessions, reset the password and preserve the logs.

Task D: Review an AI security answer

D1. Unsafe or unsupported claims and corrections

Claim or action in the AI output	Problem and correction
"The email is safe because it uses HTTPS."	HTTPS only encrypts the connection. Task B shows mismatched domains, urgency and requests for secrets, so the message is highly suspicious. Verify through an official contact, as CISA's phishing guidance advises.
"The sign in logs prove that the person using 198.51.100.23 stole the password."	Logs show events from an address, not a person. The Day 4 notes explain that IP addresses change with the network, and shared networks put many people behind one address. The logs also do not show how the password was obtained. The fair claim is possible compromise.
"MFA prevents every account compromise."	No control is absolute. In Task C a prompt was approved under pressure. MFA cuts risk a lot, and works better with number matching and user training.
"Delete the suspicious logs."	This destroys the evidence needed to scope the incident. Logs should be preserved, protected and documented.
"Send the student's password to support so they can test it."	Passwords are never shared, even with support, and nobody legitimate needs one. The Day 1 notes say to never share OTPs or sensitive personal data. Reset the password through the official process and revoke sessions.

The output also shows what NIST calls confabulation, meaning confident statements with no evidence behind them, so AI answers must be checked against the evidence.

D2. A better prompt

"Analyse only the fictional evidence I paste below, which is synthetic training data. Do not assume anything that is not shown in it. Do not ask for, accept or suggest sharing any password, OTP code or personal data. Use three headings: Observed facts, Assumptions or interpretations, and Unknowns. For every conclusion, say how confident you are, why, and what extra evidence would change it. Recommend only safe defensive steps that an authorised IT team could take, such as preserving logs and resetting credentials through official channels. If the evidence is not enough, say so instead of guessing. Evidence: [paste the synthetic log and message here]"

D3. Corrected security advice

A padlock or a familiar name does not make a message safe. HTTPS only encrypts the connection, so check the sender and the link through an official contact you found yourself. The logs show a new IP address, failed passwords, a denied prompt and an approved one. That points to possible compromise, but an IP address is not a person, so I would not name anyone yet. MFA helps a lot, but it fails when someone approves a prompt they did not start. Deny unexpected prompts and report them. Keep the logs, because they are the evidence. Never share a password or OTP, not even with support. Reset the password through the official process, end active sessions, check the recovery and MFA settings, and tell the IT team.

D4. AI use declaration and evidence notes

AI use declaration: I used Claude, an AI assistant, to help draft and structure this report from my class notes and the assessment brief. I checked the answers against the brief and the notes before submitting.

Evidence note 1: EWB class notes, Days 1 and 4, with CISA, Secure Our World. Day 1 defines vulnerability, threat and risk and says never to share OTPs. Day 4 explains that IP addresses change with the network, which is why an IP alone proves little. CISA covers updates, multifactor sign in and phishing basics.

Evidence note 2: NIST, Generative AI Profile (publication AI 600 1). Its discussion of confabulation and the need to verify AI output supports my review of the AI answer and my decision not to trust it unchecked.

References

1. CISA. Secure Our World, basic account and phishing guidance. Cybersecurity and Infrastructure Security Agency.

2. NIST. Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, AI 600 1. National Institute of Standards and Technology.

3. EWB Software Training Institute. Cybersecurity class notes, Day 1 to Day 4.

4. EWB Courses. AI Powered Cybersecurity, Assessment 01 brief, issued 18 October 2026.